

Digital Forensics & Incident Response

UNIT 5 - Incident Response Lifecycle & Forensic Reporting

Jigar Gajjar
Vice President – Academia
TechD Cybersecurity Limited

Contents

- **Introduction to Incident Response**
- **NIST Incident Response Lifecycle**
- **Incident Detection, Analysis and Classification**
- **Incident Containment and Eradication**
- **Incident Recovery and Post-Incident Activities**
- **Incident Severity and Impact Assessment**
- **Incident Response Playbooks**
- **Ransomware, Phishing and Insider Threat Response**
- **Forensic Report Structure and Documentation**
- **Findings, Recommendations and Legal Defensibility**



Introduction to Incident Response



Introduction to Incident Response

Incident Response (IR) is the organised process of identifying, analysing, containing, removing and recovering from cybersecurity incidents.

A cybersecurity incident may involve malware infection, ransomware, unauthorised access, phishing, data theft or compromise of user accounts.

The purpose of incident response is not only to stop an attack but also to **understand what happened, limit its impact, preserve relevant evidence and prevent similar incidents in the future.**

Main Objectives

- Detect security incidents quickly
- Understand the nature and impact of an incident
- Contain the threat
- Remove the cause of compromise
- Restore normal operations
- Learn from the incident



Incident Response vs Digital Forensics

Digital Forensics: focuses on the **collection, preservation, examination and interpretation** of digital evidence.

Incident Response: focuses on **managing and responding** to an active or suspected security incident.

Relationship: These two activities work closely together.

Incident Response

- Detect incident
- Contain threat
- Recover systems

Digital Forensics

- Preserve evidence
- Analyse artefacts
- Reconstruct events
- Support investigation



Incident response focuses on controlling the incident, while digital forensics focuses on understanding and proving what happened.



What is NIST SP 800-61?

NIST SP 800-61

NIST Special Publication 800-61 provides guidance for establishing and improving an organisation's computer security incident handling capability.

It describes activities associated with preparing for incidents, detecting and analysing them, containing and eradicating threats, recovering affected systems and performing post-incident activities.

The NIST Incident Response Life Cycle



Phase 1: Preparation

Preparation is the process of establishing the people, processes and technical capabilities required to respond effectively to cybersecurity incidents.

Good preparation reduces confusion and response time when an actual incident occurs.

Preparation Includes

Incident Response Plan: Defines how incidents will be managed.

Playbooks: Provide structured procedures for common incident types.

Tools and Technology: Provide capabilities for investigation, detection and response.

Training: Ensures that personnel understand their responsibilities.

Contact Lists: Provide important internal and external contacts.

Effective incident response begins before an incident occurs.



Phase 2: Detection & Analysis

Detection is the process of identifying events that may indicate a cybersecurity incident.

Security alerts can originate from:

- SIEM systems
- Endpoint security tools
- Network monitoring
- Firewall logs
- User reports
- Threat intelligence

Analysis :After detection, investigators determine whether the event is actually an incident and understand its scope.

Analysis Questions

- What happened?
- Which systems are affected?
- Which accounts are involved?
- Is the threat still active?
- What evidence is available?
- What is the potential impact?



Incident Identification and Validation

Not every security alert represents a confirmed security incident.

An alert must be **validated and investigated** before the response team determines its significance.

Example

A system generates an alert for repeated failed logins.

The investigation may examine:

Source IP → Where did the attempts originate?

Username → Which account was targeted?

Time → When did the activity occur?

Frequency → Was the activity normal or unusual?

Successful Login → Did any attempt eventually succeed?

Outcome

The event can then be classified as:

Benign activity → **False positive** → **Suspicious activity** → **Confirmed incident**



Phase 3: Containment

What is Containment?

Containment is the process of limiting the spread and impact of a security incident.

The objective is to prevent an attacker, malware or compromised account from causing further damage while allowing investigation to continue.

Short-Term Containment

Immediate actions may include:

- Isolating an affected system
- Blocking malicious IP addresses
- Disabling compromised accounts
- Blocking malicious domains



Long-Term Containment

Long-term measures address persistent access and maintain a controlled environment while remediation is performed.

Containment limits damage while preserving the ability to investigate the incident.



Phase 4: Eradication

What is Eradication?

Eradication is the process of removing the root cause and remaining traces of the threat from affected systems. After containment, investigators and response teams work to eliminate the mechanisms that allowed or enabled the compromise.

Common Activities

- Remove malware
- Remove malicious persistence
- Patch exploited vulnerabilities
- Reset compromised credentials
- Remove unauthorised accounts
- Correct security misconfigurations

The affected environment should no longer contain the known mechanism of compromise.



Phase 5: Recovery

What is Recovery?

Recovery is the process of restoring affected systems and services to normal, trusted operation.

Recovery should be performed carefully to ensure that compromised systems are not returned to production while the threat remains present.

Recovery Activities

Restore: Recover systems from clean and trusted backups.

Validate: Confirm that systems are functioning correctly.

Monitor: Closely monitor restored systems for signs of continued compromise.

Return to Operation: Gradually restore normal business services.

Recovery is complete only when systems can operate normally and remain secure under monitoring.



Phase 6: Post-Incident Activity

What is Post-Incident Activity?

Post-incident activity occurs after the immediate response has been completed. The purpose is to understand what happened and improve future incident-response capabilities.

Important Activities

Lessons Learned Meeting: Discuss what worked and what did not.

Update Playbooks: Improve procedures based on actual experience.

Update Security Controls: Address weaknesses discovered during the incident.

Report Metrics: Record relevant information about response performance.

What can be changed so that the same incident is less likely to happen again?



Incident Detection, Analysis and Classification



Incident Classification

What is Incident Classification?

Incident classification is the process of categorising a security incident according to its severity, impact and urgency. Classification helps an organisation determine **how quickly the incident must be handled and which personnel should be involved**.

Severity Levels

P1 - Critical

Major active breach, ransomware or severe business impact.

P2 - High

Significant compromise requiring urgent response.

P3 - Medium

Limited impact requiring structured investigation.

P4 - Low

Minor security event or policy violation.



The specific classification criteria should be defined by the organisation's incident-response policy.



Incident Impact Assessment

Impact assessment determines how seriously an incident affects an organisation.
An incident may affect multiple areas simultaneously.

Important Impact Factors

Confidentiality

Has sensitive information been exposed?

Integrity

Has information or a system been modified?

Availability

Are systems or services unavailable?

Business Impact

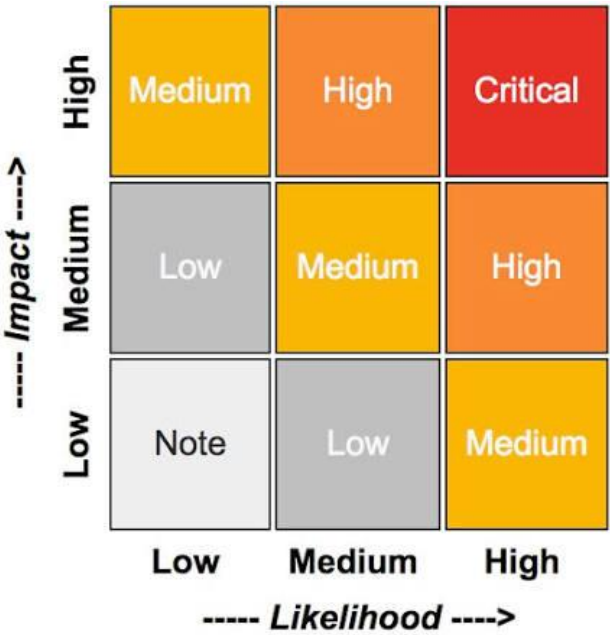
Are business operations affected?

Legal / Regulatory Impact

Are there reporting or compliance implications?

Result

Impact assessment helps determine the **priority and appropriate response level**.



SLA and Escalation

A **Service Level Agreement (SLA)** defines expected response or resolution timeframes for different types or severities of incidents.

Critical incidents generally require faster response than low-severity events.

Escalation transfers an incident to personnel with greater authority, expertise or responsibility.

Escalation May Involve

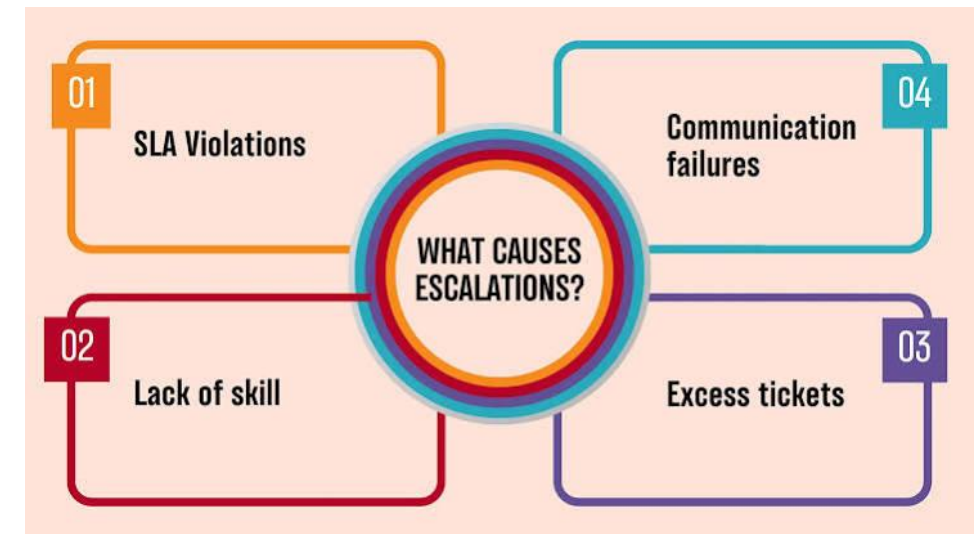
Technical Team → Investigation and containment

Management → Business decisions and prioritisation

Legal → Legal obligations and evidence considerations

HR → Employee-related investigations

External Authorities → Where legally or organisationally required



Incident Response Playbooks



What is an Incident Response Playbook?

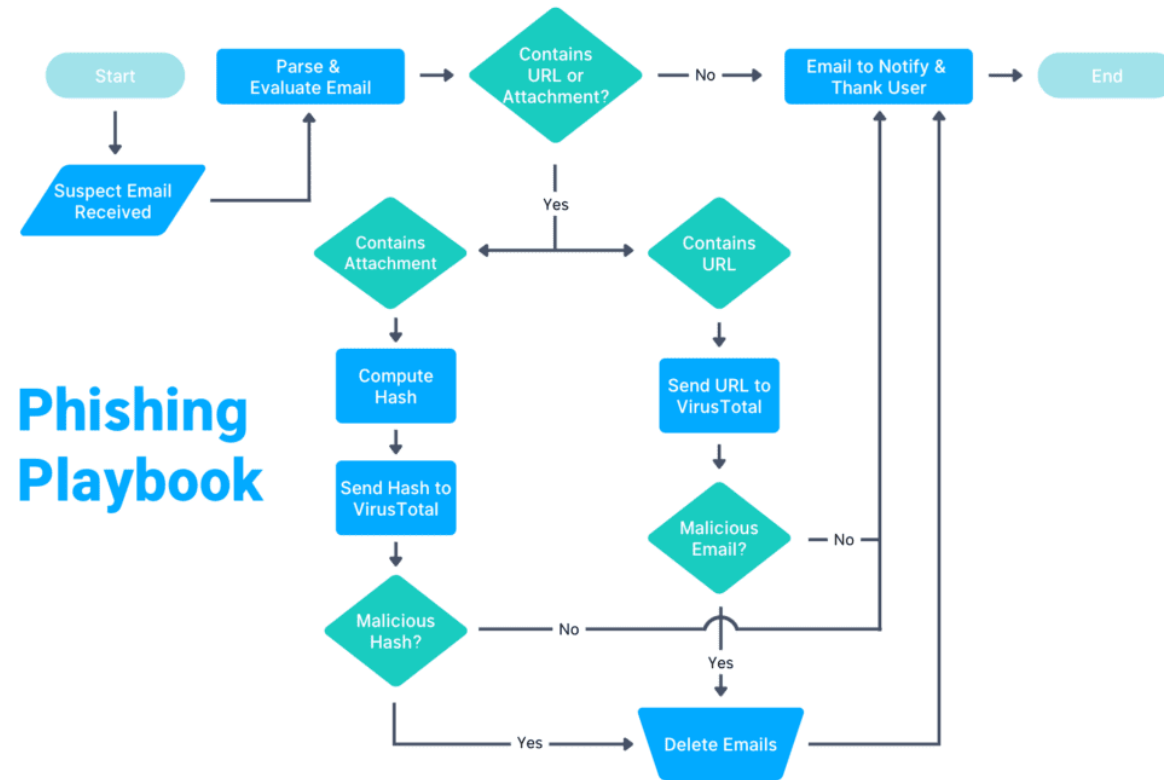
An **incident response playbook** is a structured set of procedures for responding to a specific type of cybersecurity incident. Instead of developing a response from scratch during an emergency, the response team can follow a predefined procedure.

A Playbook Typically Defines

- Initial detection
- Evidence preservation
- Investigation steps
- Containment actions
- Eradication actions
- Recovery activities
- Communication and escalation

Examples

- Ransomware playbook
- Phishing playbook
- Insider-threat playbook



Ransomware Response

What is Ransomware?

Ransomware is malicious software that typically prevents access to data or systems, often through encryption, and demands payment from the victim.

Response Process

Identify: Determine the affected systems and ransomware characteristics.



Isolate: Separate affected systems from the network.



Preserve Evidence: Capture relevant volatile and non-volatile evidence where appropriate.



Assess Backups: Determine whether clean and usable backups are available.



Eradicate: Remove the malware and address the entry point.



Recover: Restore systems from trusted backups and monitor them.

The response process should prioritise **containment, evidence preservation and safe recovery**.



Phishing Incident Response

What is Phishing?

Phishing is a social-engineering technique in which an attacker attempts to deceive users into revealing information, opening malicious content or performing an unsafe action.

Response Process

Analyse Email: Examine headers, sender information and message content.



Identify Compromised Accounts: Review authentication activity for unusual logins.



Identify IOCs: Record malicious domains, IP addresses, URLs and attachments.



Block IOCs: Prevent further communication with known malicious infrastructure.



Reset Credentials: Reset credentials where compromise is suspected.

Stop further access while determining **how the phishing attack affected the organisation.**



Insider Threat Response

An **insider threat** occurs when a person with authorised access misuses that access, either intentionally or unintentionally, in a way that creates security risk.

Investigation Approach

Insider investigations require careful handling because the suspected individual may have legitimate access to systems and information.

Important Activities

- Preserve relevant evidence
- Maintain chain of custody
- Collect artefacts discreetly
- Analyse user activity
- Document findings
- Coordinate with appropriate organisational authorities

Insider Threats:
The Danger Inside
Organizations



The investigation should be evidence-driven and carefully coordinated rather than based on assumptions.



Forensic Report Structure and Documentation



Introduction to Forensic Reporting

What is a Forensic Report?

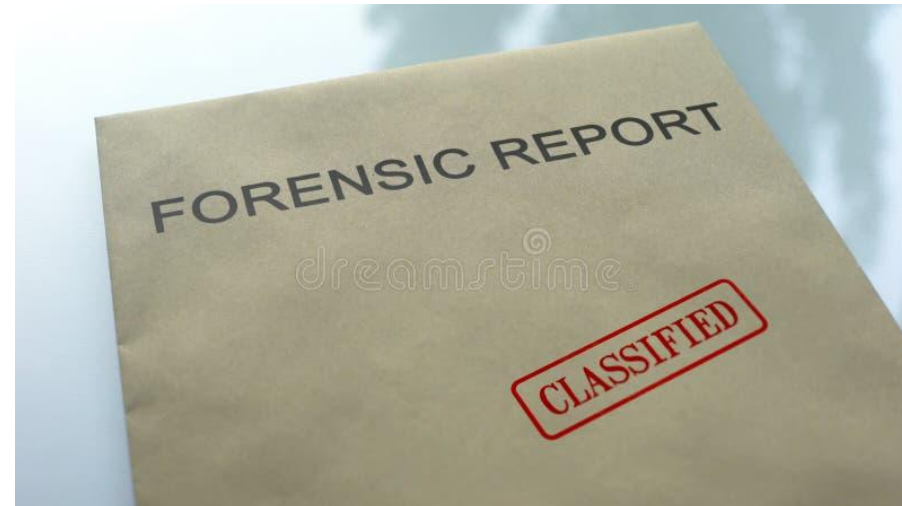
A **forensic report** is a formal document that records the scope, methodology, evidence, analysis, findings and conclusions of a digital forensic investigation.

The report transforms technical investigation results into a structured document that can be understood by **technical teams, management, legal teams and other authorised stakeholders**.

Purpose

A good forensic report should be:

- Accurate
- Clear
- Objective
- Reproducible
- Well documented
- Legally defensible



Structure of a Forensic Report

A forensic report should follow a logical structure.

Major Sections

Case Details & Chain of Custody: Identifies the investigation and evidence history.

Scope & Methodology: Defines what was examined and how the examination was conducted.

Tools Used: Documents forensic tools and relevant versions.

Findings Timeline: Presents events chronologically.

Detailed Findings: Explains each important forensic finding.

Conclusion: Summarises what the evidence establishes.

Recommendations: Suggests appropriate security or remediation actions.

Appendix: Contains supporting information such as hash values and documentation.

OFFICIAL USE ONLY

DIGITAL EVIDENCE FORENSIC REPORT

Your Logo Here

Your address here

CASE INFORMATION:

Agency Case #: _____ Originating Agency Case #: _____

[removed] #: _____ [removed] #: _____ Remedy#: _____

Distribution: ☐ [removed] ☐ [removed] ☐ [removed] ☐ IT ☐ [removed] ☐ Internal Audit
☐ Emp. Relations ☐ CI ☐ Other: _____

Date/Time Report Completed: _____ Date/Time Incident Occurred: _____

Type of Report: _____ Initial _____

INVOLVED:

☐ Involved ☐ Witness ☐ Complainant ☐ Mentioned
Name: Last: _____ First: _____ Title: _____
Mailstop: _____ Email: _____
Cell Phone: _____ Work Phone: _____ Employee #: _____

☐ Involved ☐ Witness ☐ Complainant ☐ Mentioned
Name: Last: _____ First: _____ Title: _____
Mailstop: _____ Email: _____
Cell Phone: _____ Work Phone: _____ Employee #: _____

☐ Involved ☐ Witness ☐ Complainant ☐ Mentioned
Name: Last: _____ First: _____ Title: _____
Mailstop: _____ Email: _____
Cell Phone: _____ Work Phone: _____ Employee #: _____

CLASSIFICATION LEVEL HERE

May be exempt from public release under the Freedom of Information Act (5 U.S.C. 552) exemption number and category: **7, Law Enforcement**

Department of Name of Agency review required before public release

Name/Org: Your name/org Date: _____

Guidance (if applicable): _____

Case Details & Chain of Custody

Case Details

The report should clearly identify the investigation.

- Case number
- Investigation title
- Date
- Investigator
- Evidence involved
- Investigation scope

Chain of Custody

The chain of custody documents the **history and handling of evidence** from collection through examination and storage. It helps establish that evidence was properly controlled throughout the investigation.

Important Information

- Who handled it?
- When was it handled?
- Where was it stored or transferred?
- What condition was it in?

CHAIN OF CUSTODY



Scope and Methodology

The **scope** defines what was included and excluded from the investigation.

For example, it may identify:

- Systems examined
- Devices examined
- Time period
- Types of evidence
- Investigation objectives

The **methodology** explains how the investigation was conducted.

It may describe:

- **Acquisition** How evidence was obtained.
- **Preservation** How evidence integrity was maintained.
- **Examination** How forensic artefacts were identified.
- **Analysis** How evidence was interpreted.
- **Reporting** How findings were documented.



Documenting Forensic Tools

Forensic reports should clearly identify the tools used during the investigation.

Tool Documentation

For each important tool, record:

Tool Name

Identifies the software.

Version Number

Identifies the exact version used.

Purpose

Explains what the tool was used for.

Activity

Describes the forensic task performed.

Why Version Numbers Matter

Different versions of forensic tools may process or display artefacts differently.
Recording versions therefore improves **reproducibility and legal defensibility**.



Findings Timeline

What is a Findings Timeline?

A **findings timeline** presents significant forensic events in chronological order. Each event should be connected to its underlying evidence.

Recommended Structure

Timestamp	Artefact	Event	Significance
10:05	Security Log	Successful login	Account accessed
10:12	MFT	File accessed	Sensitive file activity
10:15	USB Artefact	USB device detected	Removable media activity
10:20	Network Log	External connection	Possible data transfer

Benefit

A timeline helps convert individual artefacts into a **coherent sequence of events**.



Detailed Forensic Findings

Each important finding should explain **what was discovered and why it matters**.

A Strong Finding Contains

- **Artefact:** What evidence was identified?
- **Location:** Where was it found?
- **Timestamp:** When did the relevant event occur?
- **Observation:** What does the artefact show?
- **Forensic Significance:** Why is the finding relevant to the investigation?

Example Structure

Finding: A suspicious executable was identified in the user's temporary directory.

Timestamp: 14:32 UTC

Evidence Source: NTFS file-system artefact

Significance: The file's presence and associated activity require correlation with process, network and user-activity evidence.



Writing Objective Findings

A forensic investigator must distinguish between **evidence, interpretation and assumptions**.

Weak Statement

“The user definitely installed malware.”

This may go beyond what the available evidence establishes.

Better Statement

“A suspicious executable was identified on the system, and associated execution artefacts were observed.”

The second statement describes what the evidence actually supports.

Good Forensic Writing

- State facts clearly
- Identify the evidence source
- Explain significance
- Avoid unsupported conclusions
- Distinguish findings from assumptions

A forensic report should describe what the evidence demonstrates, not what the investigator assumes happened.



Legal Defensibility of a Forensic Report

What is Legal Defensibility?

A forensic investigation is **legally defensible** when its evidence handling, methodology, analysis and documentation can withstand scrutiny.

Important Requirements

Evidence Integrity

Evidence must be preserved appropriately.

Chain of Custody

Evidence handling must be documented.

Repeatable Methodology

Investigative procedures should be explainable and reproducible.

Tool Documentation

Tools and versions should be recorded.

Objective Findings

Conclusions should be supported by evidence.

Complete Documentation

Important investigative actions should be recorded.

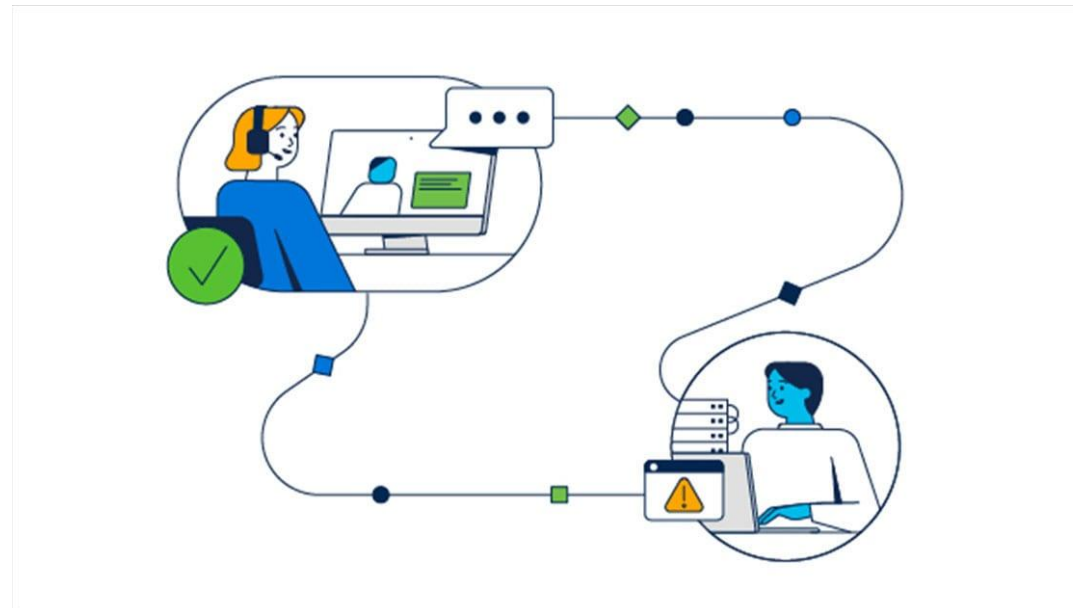


Complete Incident Response & Forensic Reporting Flow

From Incident to Final Report

Security Event → Detection → Analysis → Incident Classification → Containment
→ Evidence Preservation → Eradication → Recovery → Post-Incident Review
→ Forensic Analysis → Findings Timeline → Forensic Report → Recommendations

This connects incident response activities with digital forensic investigation and reporting.



Integrated Scenario: Ransomware Incident

Scenario

An organisation discovers that multiple systems have suddenly become inaccessible and files have unusual extensions.

Response

Detection: Identify the ransomware activity.

Classification: Determine severity and business impact.

Containment: Isolate affected systems.

Evidence Preservation: Preserve relevant memory and disk evidence where appropriate.

Eradication: Remove malware and address the exploited vulnerability.

Recovery: Restore systems using trusted backups.

Post-Incident Activity: Identify how the attack occurred and improve controls.

Forensic Report: Document the timeline, evidence, findings, conclusion and recommendations.



Thank you

